COMPTE RENDU DE TP 4.2 : DÉTECTION D'ATTAQUES AVEC UN IDS/IPS (SURICATA SUR PFSENSE)

Objectif : Mise en place d'un système de détection (IDS) et de prévention d'intrusion (IPS) pour sécuriser le réseau LAN.

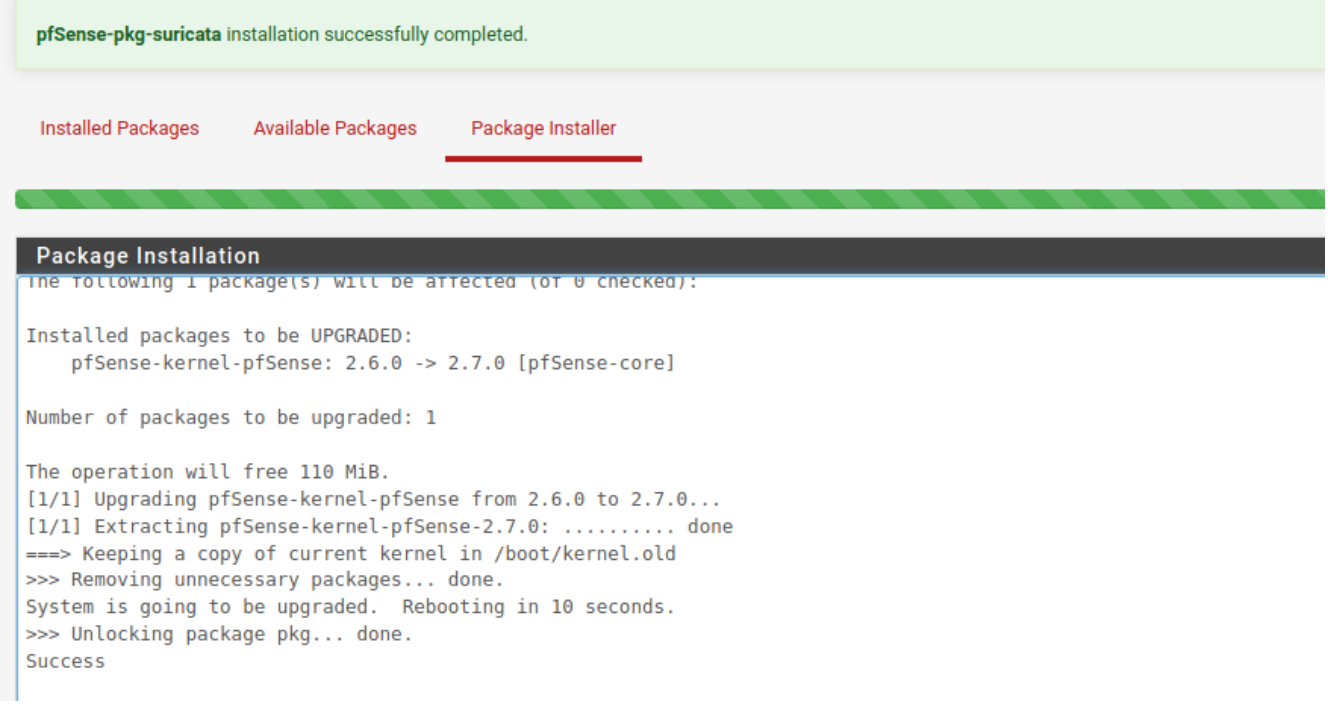
1. Introduction et Objectifs

L'objectif de ce TP est d'ajouter une couche d'intelligence à la sécurité réseau de l'infrastructure NetSecure. Alors qu'un pare-feu classique se contente de bloquer des ports, l'utilisation de **Suricata** permet d'analyser le contenu du trafic en temps réel pour identifier des signatures d'attaques spécifiques (scans, tentatives d'exploitation, etc.).

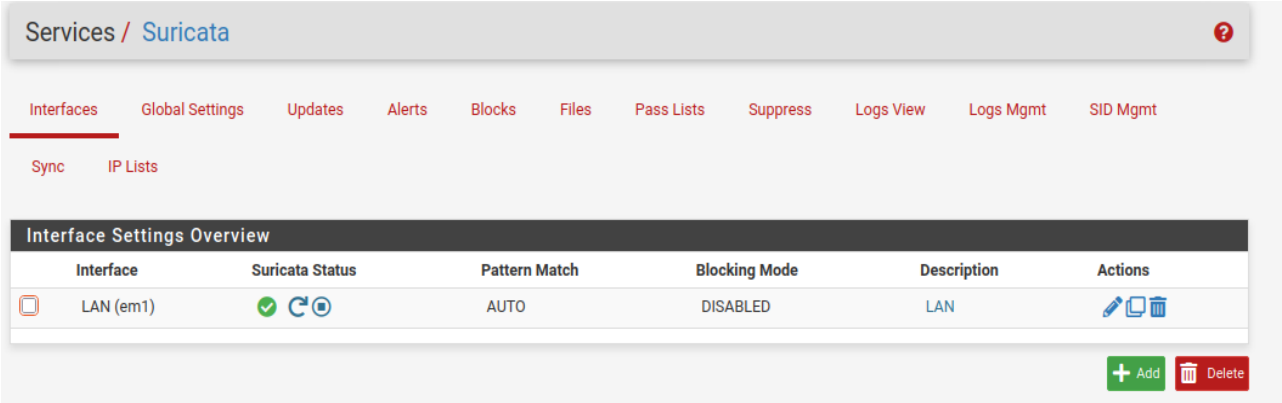
2. Mise en œuvre technique

2.1 Installation et Configuration de Suricata

L'installation a été réalisée sur l'interface pfSense via le gestionnaire de paquets.



- **Interface surveillée :** Le LAN a été choisi car c'est là que se situent les machines sensibles (Ubuntu et Windows) à protéger après une première compromission.



- **Activation des signatures :** Les règles "ET Open Rules" ont été activées et mises à jour pour permettre à Suricata de reconnaître les menaces connues.

2.2 Passage en mode IDS (Détection)

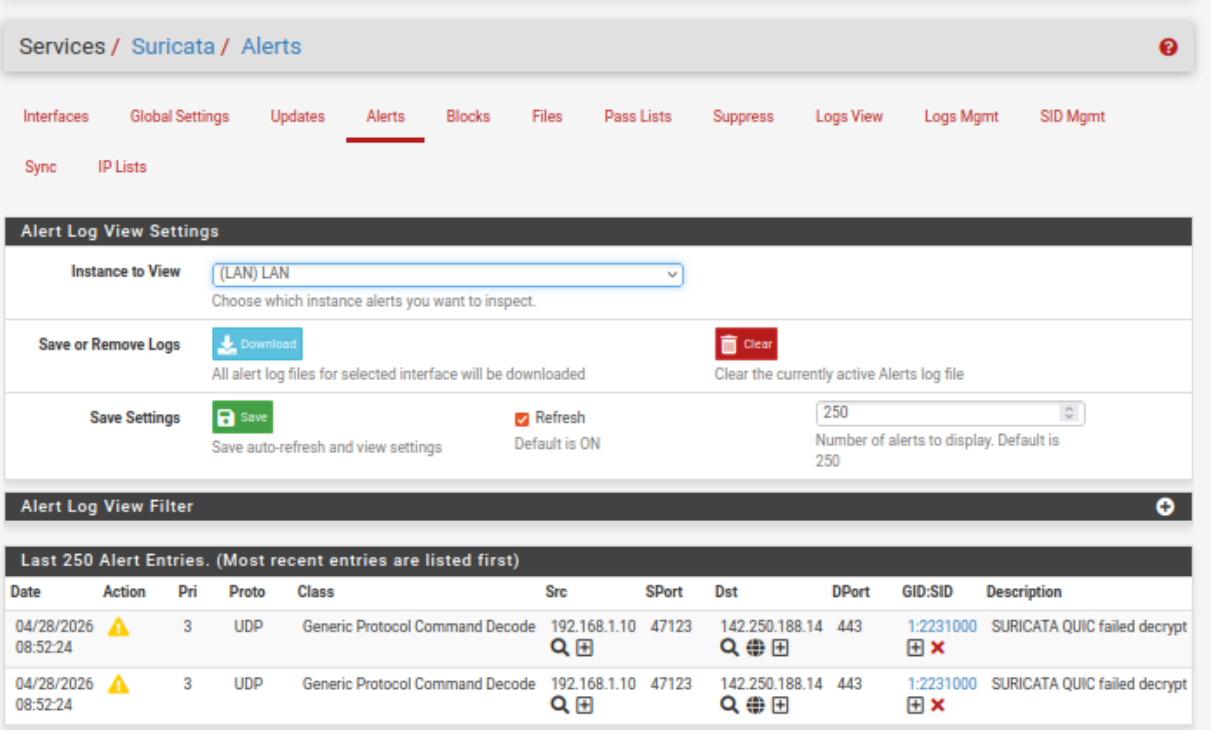
Dans un premier temps, Suricata a été configuré pour observer sans bloquer.

- **Test effectué :** Un scan Nmap furtif (***sudo nmap -sS 192.168.1.10***) a été lancé depuis Kali vers la machine Ubuntu.

D’après l’image ci-dessous, nous avons effectué 02 scans afin d’obtenir 02 alertes suricata.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 09:51 WAT
Stats: 0:00:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.00% done; ETC: 09:51 (0:00:00 remaining)
Nmap scan report for 192.168.1.10
Host is up (0.0011s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:FA:1C:6A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds

┌──(laurasimo㉿laura)-[~]
└─$

┌──(laurasimo㉿laura)-[~]
└─$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 09:51 WAT
Nmap scan report for 192.168.1.10
Host is up (0.00094s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:FA:1C:6A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.60 seconds

┌──(laurasimo㉿laura)-[~]
└─$
```

- **Observation :** Dans l'onglet **Services -> Suricata -> Alerts**, des alertes ont été générées, prouvant que l'attaque a été détectée même si elle n'a pas été bloquée.



Nous avons aussi lancer un test d'attaque via Kali Linux par la commade ***msfconsole*** afin de lancer une tentative d'exploitation avec la commande :

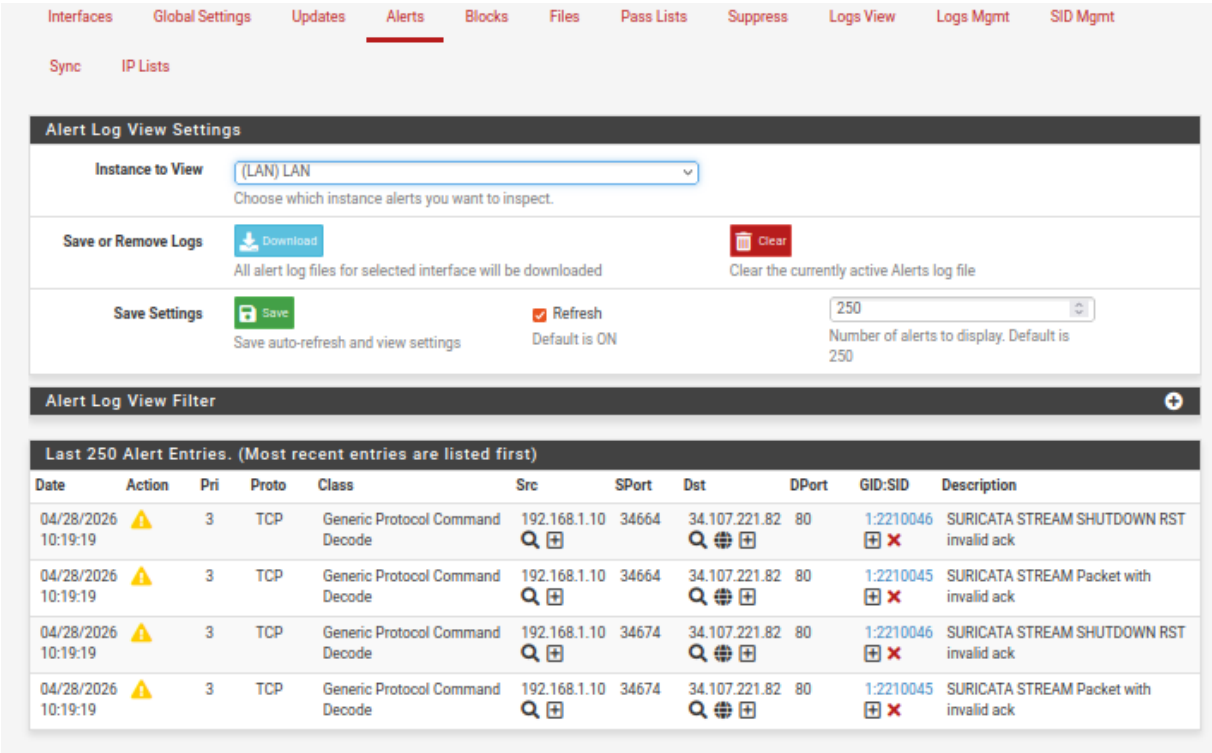
use auxiliary/scanner/smb/smb_version

RHOSTS 192.168.1.10

run

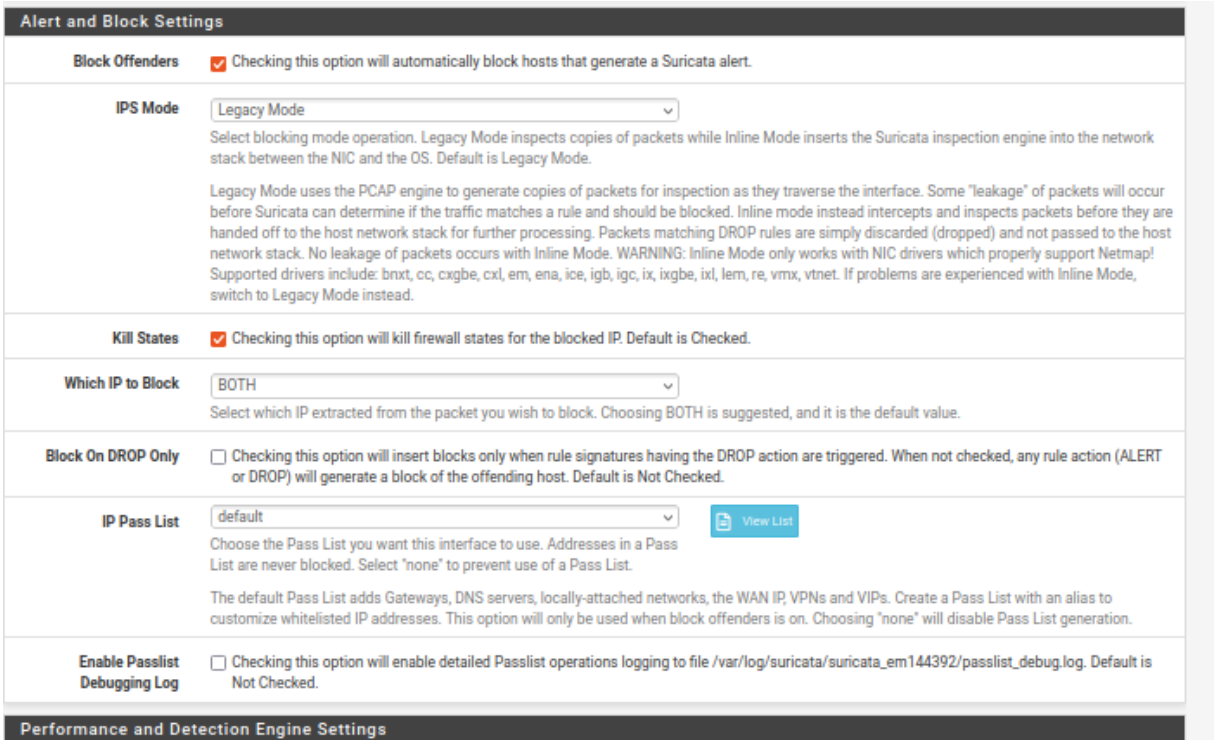
```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.1.10:         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

La figure ci-dessous presente les détections de suricata des différentes tentatives d'exploitation efectuées



Ensuite, nous allons passer en mode blocage (IPS) et lancer une tentative Nmap. Puis nous allons aller dans suricata vérifier les alertes.

Le Block Offenders est activé. Il permet de bloqué u, utilisateur suspect.



Nous avons constaté que la tentative Nmap est très lente et bloquée. La page alerte est vide.

3. Méthode de détection de suricata

La Détection par Signatures (Le "Matching")

C'est la méthode la plus courante. Suricata possède une base de données contenant des milliers de "fiches signalétiques" appelées **signatures** ou **règles**.

- **Le principe :** Chaque règle contient des caractéristiques précises d'une attaque connue (une suite de caractères spécifique, un port inhabituel, ou une taille de paquet anormale).
- **L'action :** Suricata compare chaque paquet qui passe sur le réseau avec ces règles. Si le contenu du paquet correspond exactement à une règle (par exemple, la signature d'un scan Nmap), une alerte est déclenchée.

L'Analyse de Protocole (L'Analyse Intelligente)

Suricata ne se contente pas de lire le texte des paquets ; il comprend les "langages" du réseau (HTTP, SMB, FTP, TLS, etc.).

- **Le principe :** Il vérifie si le trafic respecte les règles normales du protocole.

- **Exemple :** Si quelqu'un essaie d'envoyer des commandes de terminal à travers une connexion qui devrait être uniquement du trafic web (HTTP), Suricata détecte cette anomalie car elle ne respecte pas la structure normale du langage HTTP.

4. Analyse et Compréhension

4.1 Différence entre IDS et IPS

- **IDS (Intrusion Detection System) :** Agit comme une caméra de surveillance. Il voit l'attaque, génère une alerte, mais ne l'arrête pas.
- **IPS (Intrusion Prevention System) :** Agit comme un agent de sécurité. Il détecte l'attaque et ferme immédiatement l'accès pour protéger la cible.

4.2 L'importance des signatures

Suricata utilise une base de données de milliers de signatures. Sans ces règles mises à jour, l'outil serait incapable de distinguer un trafic légitime (comme une mise à jour logicielle) d'une activité malveillante (comme une tentative d'exploitation Metasploit).

5. Options avancées de Suricata

Lors de l'utilisation de l'outil, plusieurs paramètres permettent d'affiner la détection :

- **Types de règles :** Filtrage par protocole (HTTP, SMB, FTP) ou par comportement.
- **Niveaux de sévérité :** Les alertes sont classées pour aider l'administrateur à prioriser les menaces critiques.
- **Gestion des suppressions :** Possibilité d'ignorer certaines alertes pour éviter les faux positifs.

6. Conclusion

Ce TP a validé un point essentiel : les attaques réalisées précédemment (Nmap, Metasploit) sont désormais détectables et blocables. L'intégration de Suricata sur pfSense transforme un pare-feu statique en une barrière dynamique capable de réagir aux comportements anormaux, ce qui est crucial dans un environnement SOC moderne.